

Handoff — M1.13b Close-Out + M2 Sub-Issue Kickoff (focused session)

⚠ **NEWEST — 2026-07-31 ~13:45. Merge-readiness audit landed. One REAL security bug found and fixed.**

Both big workflows finished. 18-agent merge-readiness audit (13 findings confirmed, 1 refuted) and 8-agent M2 breakdown (7 parents → 32 filable sub-issues).

The security bug — fixed, measured, documented

`add_carveout_rule (bin/gv-sandbox/main.rs)` canonicalised its path **before** validating it. A Landlock rule lands on the resolved object, not the name — so a `~/.ssh/known_hosts` that was a **symlink to `~/.ssh/id_rsa` granted read access to the private key**, by its real path, while `--exclude ~/.ssh` still looked intact. This was in #188's code, landed this morning, and no test caught it.

Fixed with a `symlink_metadata` check placed before `canonicalize` (canonicalising first destroys the evidence). A dangling symlink refuses too, rather than falling through to the tolerated `Absent` outcome. **Closure measured, not argued:** deleting the check fails exactly two tests and no others. Recorded as ADR 0033 §1a, with a `sequenceDiagram` of the attack.

Note the class: `enumerate()` already guards this exact hazard (`real.starts_with(root)`), but containment could not be reused here — the dangerous target sits in the same directory as the legitimate one, so the carve-out's rule is stricter: the named path must **be** the file, never point at one.

Seventh green-but-wrong finding — and it was inside the contract itself

R3 (`escape_contract.rs`) guarantees every case's paired positive is really asserted. Its check was `body.contains("expect_granted") && body.contains("\nGRANTED\n")` — but both substrings occur in `execute` for unrelated reasons (`expect_granted_provenance` contains the first, the second is a parse tag), so dropping the real comparison would have left it green. Now matches the call: one `observation_mismatch` taking both the GRANTED tag and `case.expect_granted`, (trailing comma discriminates it from the provenance field), with its result consumed. Added `call_args_in` — a paren-balanced call extractor — because substring checks cannot tell "both tokens appear" from "both tokens are arguments to the same call".

State

- `./dev gate` **green**. 456 passed / 0 failed / 2 ignored. 174 sandbox tests.
- 18 escape cases, 11 mutants, matrix `PASS`.
- **gitleaks now passes in CI** — the two-part fix worked.

- PR #207 body rewritten: now Closes #66 **and** Closes #188, counts corrected (401→456, 17→18 cases, 10→11 mutants), the symlink bug and the R3 vacuity written up.

• 66's checklist fixed — the "Open" section had 10 closed items under it. Now only #203.

Next

1. **#203 needs an operator decision, not code.** Its recorded D6 conflict: the plan says `sysctl-write-and-fail-loudly`, `ci.yml` argues the opposite in a comment and has no such write. The job itself has passed on this branch (run 30647723490). This is the only thing #66 is blocked on.
2. **Tom drives the app** — testbed on 8081. #65's a11y work has never been human-verified.
3. Then mark #207 ready and merge.
4. M2 breakdown saved to `design-docs/2026-07-31-m2-subissue-breakdown.md` (136 KB, 32 sub-issues with model/effort/sequencing). Nothing filed on GitHub yet — deliberate.

Still-unfixed audit findings (all non-blocking, all confirmed)

- ADR 0030's line-number citations have rotted (5 verified wrong — one for `fn main()` lands in symlink-handling code). A workflow is de-rotting these to symbol anchors.
- ADR 0030 misquotes `trust.rs`'s `grant()` doc comment — presents a phrase as a direct quote that is not in the source. Underlying fact (no production caller) is still true.
- `blocked_hooks`' R3 paired positive restates a fact already asserted moments earlier, so it cannot independently fail. Cosmetic; the case's real weight is the marker-file check.

2026-07-31 ~13:05. #188 DONE. CI green except gitleaks (fix pushed, unverified in CI).

#188 is genuinely finished and adversarially verified. 173/173 sandbox tests pass. A skeptic independently confirmed: Strict tier still denies `known_hosts`, private keys stay denied in the Network tier, and the fix is real rather than test-shaped. The earlier "EACCES bug" in the block below was NOT a real defect — it was a half-built tree captured mid-flight by the 60s checkpointer, because the previous session's #188 workflow died at its implement stage on a quota limit. At current HEAD the mechanism traces cleanly end to end (`Policy::ro_carveouts` → `--ro-carveout` → `add_carveout_rule`).

Mutation matrix: PASS, run locally in full. M11 (the new #188 mutant) kills ONLY `ssh_known_hosts_carveout` — narrow closure, so that case is load-bearing, not vacuous.

Two real CI failures found and fixed this stretch:

1. **Mutation matrix (R9) was red** — `ci/mutants/M3-empty-secret-excludes.patch` no longer applied: #188's doc comments moved `secret_excludes_for_home` from line 193 to 252. Regenerated the patch; all 11 mutants now apply under both `git apply` and `patch -p1`. **Sandbox job is now green in CI.**

2. **gitleaks was red** — `.github/actions/host-sandbox-setup/action.yml` wrote a placeholder `~/.ssh/id_ed25519` whose first line was a literal `-----BEGIN OPENSSH PRIVATE KEY-----`. Not a real secret (nothing parses it; generated on an ephemeral runner). Fixed in two parts: reworded the placeholder so new commits don't re-trip it, and added `.gitleaks.toml` because the scan is **full-history** and commit `8e2cec7` still carries the old text.

READ `.gitleaks.toml`'s header before touching it. Two allowlist shapes were tried and both FAILED OPEN, measured against gitleaks 8.30.1: a `paths` entry, and `paths + commits` with `matchCondition = "AND"`. In both, a freshly planted real PEM key at that path in a brand-new commit went **undetected** — the file would have been blinded to real key material permanently. Final config scopes by `commits` (one immutable historical commit) instead. Verified with a paired test that must be re-run after any edit: (a) repo scan clean, and (b) a real PEM planted at that same path in a different commit **is still caught**. Leg (b) is the one that matters — it is what distinguishes a scoped suppression from a disarmed scanner. gitleaks is NOT installed on this box; the pinned checksum-verified binary used for these runs is at `<scratchpad>/gitleaks` (8.30.1, same SHA as CI).

CI status at handoff: Core, Frontend, Lint, Contract, Security audit, **Sandbox** all pass. Gitleaks fix is pushed but its CI re-run had not reported yet — **confirm it before merging**.

TWO WORKFLOWS WERE STILL RUNNING when this was written (they survive a compact; they only die if the session dies or quota exhausts): - `wf_bd2db6c5-46e` — merge-readiness audit for PR #207 / #66. Four read-only lenses (vacuous tests, docs currency, issue bookkeeping, code diff), each finding then adversarially verified by a second agent instructed to refute it. Returns confirmed vs refuted findings. - `wf_ce966f8c-60d` — M2 sub-issue breakdown for the parents with nothing filed yet (#71-#75, #153, #170), ending in a synthesis pass that finds cross-issue shared-file conflicts and the real critical path. **Drafts only — it does not create issues.**

Read both results before merging #66; the audit exists specifically to catch what this session might have missed.

Deliverable for Tom: `design-docs/2026-07-31-two-week-commit-graph.pdf` — a real commit graph (SVG lanes, curved branch/merge edges, colored nodes) styled like the app's own graph view. 195 commits, 45 merges, 5 lanes. Checkpoint commits are collapsed out but their edges are rewired to the nearest surviving ancestor, so the topology drawn is the true one. Generator: `<scratchpad>/build_svg_graph.py`.

Next steps, in order: (1) confirm gitleaks green in CI; (2) read both workflow results and fold in anything confirmed; (3) Tom drives the iPad testbed on 8081 — #65's a11y work has never been human-verified and this milestone has produced six green-but-wrong findings; (4) mark PR

207 ready and merge; (5) close #66, which unblocks #67/#72/#73/#74.

⚠ **NEWEST STATUS — 2026-07-31 ~12:15, session at 95%, resets in ~1hr, stopping per standing rule**

PR #207 CI is green (all 7 checks) — that part from the block below still holds.

#188 (SSH known_hosts + agent-socket carve-out, Network tier only) landed in code but is NOT green. `cargo test -p git-vista-server sandbox::` = 163 passed, 3 failed:

1. `sandbox::escape_contract::f_every_observation_requires_typed_kernel_provenance` — expects 17 typed-provenance entries, got 16. The new `ssh_known_hosts_carveout` case's GRANTED positive was never registered in whatever table `escape_contract.rs` (~line 1387) counts.
2. `sandbox::escape_contract::r5_census_names_exactly_the_declared_cases` — R5 census mismatch: `ssh_known_hosts_carveout` exists as an `EscapeCase` in `escape_suite.rs` but is missing from `docs/sandbox/escape-census.txt`.
3. **The real bug**, `sandbox::escape_suite::ssh_known_hosts_carveout` — ESCAPED — inside GRANTED wanted `errno 0` got 13 — R3's paired positive failed, the policy denied more than the claim. `errno 13 = EACCES`. The grant is constructed in the Policy struct (`ssh_known_hosts_carveout()` at `mod.rs:275-276`, wired at two call sites, `mod.rs:1129` and `mod.rs:1261`) but is **not actually reaching kernel-level enforcement** — either Landlock/bwrap never consumes that field, or a broader `$HOME/.ssh` deny is applied with higher precedence and shadows it. Not diagnosed further by hand — see workflow below.

A background workflow is running to fix this (`wf_1d34c0f0-ea4`, launched ~12:10, model sonnet/effort xhigh per your direction this session): two parallel diagnosis agents (bookkeeping fix for #1/#2, root-cause trace for #3) → one apply agent → one skeptic verify agent that reruns tests, checks `git diff` for a real fix vs. a test-gaming hack, confirms Strict tier still can't reach `known_hosts`, and confirms private SSH key material is still denied (paired negative). **Check /workflows or wait for its completion notification before doing anything else with #188.** If this handoff is being read because the session that launched it died before the notification landed: read `journal.jsonl` in the workflow's transcript dir (`/home/tom/.claude/projects/-home-tom-projects-Git-Vista/b8ed43d5-a9b7-482a-8492-7aa1ff90454e/subagents/workflows/wf_1d34c0f0-ea4/`) for what each agent actually returned, then `git diff` / `cargo test` to see what landed for real — do not trust a stale summary.

Do NOT mark PR #207 ready or attempt to close #66 involving #188 until this workflow's verify stage confirms green + adversarially sound. #66 itself does not depend on #188 (SSH carve-out is issue #188, separate from #66's own closure per the block below), so

207/#66 closure can proceed independently if you want to defer #188 — but if #188's

half-landed state is left as-is, `cargo test -p git-vista-server` will show 3 failures until someone finishes or reverts it.

⚠️ PRIOR STATUS — 2026-07-31 ~10:45, session at 96% context, stopping to compact

P1a and P1b are DONE and verified. Do not redo them. What landed:

- `.github/actions/host-sandbox-setup/action.yml` (new composite action) provisions bwrap + build-essential, the users unclamp (D6 Option A, moved verbatim out of the `sandbox` job), a global git identity (#203), and `~/.ssh/known_hosts`. `core`, `contract` and `sandbox` all uses: it right after checkout.
- **Three** host gaps, not two — each masked the next. The third, `~/.ssh/known_hosts`, is what `secret_read_denied` reads as its `SECRET` under `expect_baseline: Errno(0)`; without it the baseline returns `ENOENT` and the case hard-fails with "proved NOTHING".
- New tripwire
`every_ci_job_that_runs_this_crates_tests_provisions_the_host_capabilities_they_need` in `escape_contract.rs` asserts set equality between "jobs running this crate's tests" and "jobs referencing the action". Bite-tested with 7 mutations.
- `ci_preflight_host_meets_the_declared_minimum` now also checks the `$HOME` prerequisites, so an unprovisioned runner is named at the preflight.
- Fixed two tests that silently deleted their own assertions via `if Path::new(&secret).exists()` — `sandbox/spawn.rs` and `sandbox/shim_cli.rs`.
- Corrected the tripwire doc comment that overclaimed hole 7 as closed (it is a substring scan; a stub that echoes the tokens passes — demonstrated).

CI result: Core went 111 failures → green. Contract → green. Lint/Frontend/Audit/Secrets green. The `sandbox` job has NOT yet completed a full run — it is the slowest job and the 60s checkpointer keeps triggering `cancel-in-progress`. **To get a clean sandbox result: stop editing tracked files and let one run finish.** Verified locally instead — under a runner-shaped `$HOME` containing only what the action provisions, `cargo test -p git-vista-server` is 446 passed / 0 failed, and removing `known_hosts` reproduces the exact CI failure.

Also done: P5 in full (`SECURITY_MODEL.md` banner, #66's stale #208 checkbox, ADR 0030 addendum). P3 testbed rebuilt at 8081 — Tom carved testbed branches out of the never-delete rule ("temp by nature"), and `dev`'s printed resume command was wrong (no `$dir/target/`); both fixed in `dev`.

P6 (C11): closed with live residue. See `.claude/parallel/claude-result-C11-closure.md`. The central charge is dead. Residue worth acting on before closing #66: `policy_for_clone` has ZERO escape-battery coverage — either cover it or give it an honest entry in `documented_gaps.rs`.

Deliverable: design-docs/2026-07-31-milestone-next-steps.md + .pdf (27pp) — M1 + M2 to sub-issue level with model/effort/duration. Note #67 and #74 ALSO depend on M1.13, so closing #66 unblocks four issues, not two.

COMPLETED THIS FULL SESSION: - P1a/P1b: Host-provisioning action built, CI fully green (all 7 checks), triple-gap fix verified - Clone-coverage gap: Closed with honest documented_gaps.rs entry + tripwire - C11 review: Closed, 4/5 rows traced to real production path, residue resolved - Sub-issues: #209-#215 filed (7 issues, M2 slices for #68/#69/#70) - Milestone names: Fixed M2-M7 titles to match content - Testbed: Rebuilt at 8081, dev resume commands corrected - Ruleset: Extracted to .github/main-release-gates.ruleset.json, ready to apply - Progress report: design-docs/2026-07-31-session-progress-report.pdf (8pp, 7 diagrams, rendered clean) - In flight: Issue #188 SSH carve-out (research done, implement + 2 skeptics running)

Next step: Wait for #188 workflow to complete, then mark PR #207 ready for review (CI is clean). Apply ruleset if desired. Continue M2 sub-issue work or #188 follow-up per your priorities.

Written: 2026-07-31T08:12:12-04:00 · **Signed:** thomas2025 · 2026-07-31T08:12:12-04:00

This file is for a **brand-new Claude Code session** opening in /home/tom/projects/Git-Vista with **no memory of any prior conversation**. It is scoped to one job: **finish milestone M1.13b (issue #66, PR #207) and start filing/picking up the M2 sub-issue breakdown**. It is deliberately self-contained — read this file and you have everything needed to start without re-reading design-docs/2026-07-31-milestone-plan.md first (though that plan is the full source of truth if you need more detail than the summary below).

THIS IS NOT YOUR ONLY JOB IN THIS REPO — read this before touching anything

There is likely **another Claude session running in this same repo right now**, working on the iOS-Shortcuts-bridge brainstorm, tracked in the repo's regular handoff.md (gitignored, repo root). **That work is NOT yours**. Do not pick it up, do not edit handoff.md's content about it, do not duplicate effort. Your scope is the punch list and sub-issues below, full stop. If you finish those and have budget left, check in before wandering into other tracked issues.

CRITICAL — coordination rules, read before any git or server action

1. A background git-checkpointer may already be running — check before starting one

A background `autocheckpoint` process may **already be alive** for this repo from a different session/window. Only **one** checkpointer may write git history at a time — two running concurrently will race the same commit and can corrupt it.

Before doing anything else, run:

```
pgrep -af autocheckpoint
```

- **If it shows a process** (e.g. `bash /home/tom/.local/bin/autocheckpoint /home/tom/projects/Git-Vista ...`) — **do not start a second one**. Just work; the existing one is already checkpointing your commits every ~60s.
- **If nothing shows** — start one, continuing the checkpoint series. Find the highest existing number first:

```
git log --oneline -30 | grep -o 'auto-checkpoint [0-9]*' | head -5
```

As of this writing the highest is `auto-checkpoint 537`, so a freshly started checkpointer should use `START_N=538`. Re-check at the time you actually start it — it may have advanced. Launch via the shared script, not hand-rolled:

```
autocheckpoint /home/tom/projects/Git-Vista <scratch-dir> 60 66
```

(60-second interval, issue number 66 for the commit message tag.)

2. NEVER restart the dev server without asking Tom first

Port 8080 is Tom's **live iPad session** right now. Do not run `./dev serve`, `./gv`, `gv --stop`, or the raw binary, and do not stop/restart anything already running. If a task genuinely requires driving the live app (e.g. a testbed pass), that is explicitly **Tom's own action** (see P3h below) — not something this session executes. Ask first, always.

3. Never delete branches. Commit as `claude_2010`.

Standing repo rule: every fix goes on its own branch, PR, merge to main, **branch is never deleted** afterward (no `git branch -d`, no GitHub auto-delete). Claude's commits use author `claude_2010` with email `262510778+tom2025b@users.noreply.github.com` — `./dev wip` sets this automatically; if committing manually, set it per-commit, not globally.

4. Subagents never touch git

If you fan out to subagents for research/drafting, **none of them may run `git add/commit/push/checkout/switch/reset/rebase/stash`, delete a branch, or run `./dev wip`**. The background checkpointer is the sole git writer. Subagents read, draft changes (exact `old_string/new_string`), and hand them back for a single agent to apply — see the two-phase pattern in the plan's Section 4.

TOP 5 PRIORITY ACTION ITEMS — start here

Full detail and verification trail is in `design-docs/2026-07-31-milestone-plan.md`; this is the executive summary so you can act immediately.

- 1. P1a — Fix the CI preflight gap (hard blocker on PR #207).** `.github/workflows/ci.yml` only adds the host-capability setup (bwrap + users-unclamp preflight) to the `sandbox` job. Since M1.13b routes every git spawn through the sandbox chokepoint, the `core` and `contract` jobs now hit the same Strict-tier construction with no preflight — `CapabilityAbsent` is a deliberate hard failure, so **111 tests fail in Core** and the **Contract job fails outright**. Fix: add the same host-capability setup step to `core` + `contract` jobs. **Model/effort: sonnet, medium.** ~30–45 min, single-agent, one YAML file.
- 2. P1b — Fix the escape-battery fixture git-identity gap (hard blocker).** `escape_contract.rs::fixture()` deliberately builds a repo with **no local git identity** (by design — identity should flow through the sandboxed `$HOME` grant, not be hard-coded). This works on Tom's box (configured `~/.gitconfig`) but a fresh GitHub Actions runner has none, so the seed commit fails before any sandbox invariant is exercised — **17/17 escape+hook tests fail in the Sandbox CI job**. This is exactly what issue **#203** already tracks. Fix at the CI-environment level (e.g. `git config --global` step in the workflow) — do **not** touch R7's pinned-env- profile intent in the fixture itself, that's the wrong layer to patch. **Model/effort: sonnet, high** (needs judgment to fix at the right layer). ~20–40 min, single-agent, same PR as P1a likely.
- 3. P3 + P3h — Rebuild the stale testbed, then get Tom's human-in-the-loop pass.** `~/projects/Git-Vista-testbed-8081` is pinned at auto-checkpoint 525 — **12 checkpoints behind** current tip (537) — and predates both the Codex provenance-repair fix and today's CI run. Its recorded resume command in `handoff.md` (`./target/debug/git-vista-server` from inside that dir) will also fail as written — no `target/` exists there; the binary actually built into the main tree's shared `CARGO_TARGET_DIR`. Rebuild the testbed fresh (haiku/sonnet, low effort, ~2 min) before asking Tom to drive the human testbed pass (his action, 15–30 min) — this is the repo's own Definition of Done requirement, not optional.
- 4. P2 — Mark PR #207 ready for review, but only after P1a/P1b are green.** Currently `isDraft: true`. Marking ready with 3 failing checks would surprise Tom — fix the CI gaps first, then either mark ready or explicitly flag remaining red checks to him. (Note: this repo is on a free GitHub plan, branch protection returns 403 — these checks are almost certainly not merge-blocking at the platform level; `./dev gate ./dev verify` is the gate that actually matters here.)
- 5. P6 — Explicitly close the C11 residual-risk thread before merge.** C11 (2026-07-29 adversarial review) found 0/5 sampled escape-battery tests "PROVES containment" because they ran through a since-deleted test harness (`shim_cli::launch`) instead of the real production path. Strong structural evidence this is fixed (a tripwire test, `r6_every_inside_leg_spawns_through_the_production_seam`, explicitly guards against the deleted path and passes today) — but nobody has written the explicit "re-read C11's five-test table against current line numbers, confirm each row now passes" closure the way Task 28 did for its finding. **Model/effort: session**

model (opus), high — this is exactly "adversarial verify, security boundary, the one stage that must not be wrong." ~45-90 min. Optionally pair with an independent crosscheck agent, mirroring the Task 27 implementer+verifier pattern already used successfully on this branch.

Lower priority but in the plan: P5 (three small docs-currency drifts — SECURITY_MODEL.md banner, ADR 0030 addendum, issue #66's stale #208 checkbox — sonnet, low/medium, ~15-20 min, good small fan-out candidate); P4 (issue #65 real-device iPad accessibility verification — human action, not agent work); P7 (#188 SSH carve-out — explicitly deferred by Tom, not blocking #66).

After #66 closes: M2 sub-issue breakdown (not yet filed on GitHub)

The plan proposes filing sub-issues under the existing M2 parent issues (#68 – #75, #153, #170 — content is "Daily Work: Status to Push" per docs/GIT_CLIENT_ROADMAP.md; note the milestone object titles in GitHub are one step out of sync with the issue title-prefix numbering — see plan Section 2.1, an editorial call for Tom, not something to silently fix).

None of these sub-issues exist yet — the plan proposes them; filing and/or picking them up is Tom's call, and closing #66 unblocks two of the parent issues directly (#72 and #73 both explicitly name M1.13 as a dependency).

Quick reference (full model/effort/workflow/timeline tables are in the plan's Sections 3–5):

Parent	Proposed sub-issues	Notes
#68 (Status)	68f (close-out, verification only)	sonnet, low
#69 (Diff)	69e (accessible nav), 69f (perf budget)	sonnet, medium
#70 (Staging)	70a→70e, sequence a→b→c then d/e can fan out	mixed sonnet medium/high
#71 (Discard)	71a (typed ops, irreversible — adversarial-verify candidate), 71b (UI)	sonnet high/medium
#72 (Commit)	72a→72b sequence, then 72c/72d parallel; 72b is adversarial-verify candidate (rewriting shared history)	sonnet medium/high
#73 (Remotes)	73a→73b→73c→73d strict sequence; 73b (credentials) is opus-level adversarial-verify	sonnet + opus for 73b
#74 (Tags)	74a, 74b — good parallel-fan-out candidates	sonnet low/medium
#75 (PWA)	75a (cites ADR 0032 directly — no service worker), 75b	sonnet medium
#153 (MCP server)	153a (read-only tools) then 153b (write-capable — opus adversarial-verify, new less-trusted caller of the write path)	sonnet then opus
#170	Standalone, no split — well-scoped perf refactor	sonnet medium

Workflow guidance in one line: single-file/human-only tasks get no workflow; genuinely independent files (68f, 69f, 74a, 74b, 75a, 75b, 153a, 170) are good parallel

fan-out; anything touching a shared file (`planner.rs`, `git_cmd.rs`, `styles.css`, `ci.yml`) uses the two-phase research-then-single-writer pattern, never parallel `Edit` calls on the same file.

Reference: source plan document

Everything above is summarized from `design-docs/2026-07-31-milestone-plan.md` (written 2026-07-31, verified against the repo, GitHub, and a local CI run — not inferred from the milestone brief). Go there for: the full root-cause mermaid diagrams for P1a/P1b, the complete punch-list table (Section 1's summary table), the full sub-issue breakdown prose (Section 2.3), the complete model/effort table (Section 3), the complete workflow-verdict table (Section 4), and the complete timeline table (Section 5). That document itself is marked as a **strong draft** pending Tom's sign-off on the sub-issue breakdown and timelines specifically — the CI/testbed/C11 punch-list findings (Section 1) are independently verified facts, not proposals.

Signed: thomas2025 · 2026-07-31T08:12:12-04:00